

QA LAB BRASIL

Guia de referência - QA Lab Brasil

Autenticação e Autorização

Login, sessão, cookies, tokens, JWT, OAuth, OIDC, SSO, MFA e controle de acesso.

Authentication x Authorization

Autenticação responde quem é o usuário. Autorização define o que esse usuário pode fazer. Um usuário autenticado acessar uma função administrativa sem permissão é uma falha de autorização.

Sessões e tokens

Aplicações podem usar cookies de sessão ou tokens. JWT é um formato de token; OAuth 2.0 é um framework de autorização; OpenID Connect adiciona uma camada de identidade sobre OAuth 2.0.

SSO e MFA

Single Sign-On permite reutilizar uma identidade entre aplicações. Multi-Factor Authentication exige fatores adicionais e precisa ser testado em sucesso, falha, recuperação e expiração.

Cenários de QA

Valide credenciais inválidas, logout, expiração, acesso por perfil, troca de usuário, URLs protegidas, sessão simultânea e mensagens de erro sem exposição indevida.

QA Tip: Login funcionando não prova que autorização está correta: sempre teste perfis e recursos protegidos.

Official: https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html